

Client Organization: Botium Toys, Inc.

Assigned Lead Cybersecurity Analyst: Matthew Abegyah

Framework Baseline: NIST Cybersecurity Framework (CSF) v1.1

Regulatory Standards Audited: PCI-DSS v4.0, EU GDPR

Table of Contents

1. Project Overview & Objective	Error! Bookmark not defined.
Scenario	Error! Bookmark not defined.
2. Audit Scope & Managed Assets	3
Audit Scope	3
Assessment Goals	3
Current Assets Inventory	3
3. Risk Assessment & Baseline Security Posture	4
Risk Description	4
4. Controls Assessment Checklist	5
Administrative Controls Assessment	5
Technical Controls Assessment	5
Physical / Operational Controls Assessment	6
5. Regulatory Compliance Gaps	6
PCI-DSS Assessment (Financial Protections)	6
EU GDPR Assessment (European Privacy Standards)	7
6. Recommendations for Botium Toys IT Manager:	7

1. Executive Summary

Business Context and Threat Landscape

Botium Toys, Inc. is currently undergoing a rapid digital transformation, scaling its domestic U.S. e-commerce footprint into international European Union (E.U.) markets. While this expansion presents significant revenue opportunities, it continuously increases the organization's attack surface, subjecting it into a strict international data privacy legal framework.

Objective

The objective of this comprehensive governance audit is to execute a rigorous gap analysis of Botium Toys' existing plans against the NIST Cybersecurity Framework (CSF). This assessment identifies critical technical vulnerabilities, documents severe regulatory non-compliance liabilities (**PCI-DSS and GDPR**), and provides an actionable roadmap to improve the organization's security posture to an internationally accepted baseline.

2.0 Assessment Scope and Corporate Assets Inventory

2.1 Audit Boundary

The scope of this audit involves the entire enterprise operational ecosystem of Botium Toys. This includes all physical corporate headquarters, adjoining warehouse facilities, on-premises and remote end-user infrastructure, core database architecture, and internal business processing workflows.

2.2 Assessment Goals

The goal is to assess existing assets and complete the controls and compliance checklist to determine which controls and compliance best practices need to be implemented to improve Botium Toys' security posture.

2.3 Assets Inventory

The following assets currently managed by the IT department were tracked and included in the assessment perimeter:

- **Endpoint Fleet:** Corporate-issued desktops, laptops, mobile assets, and peripheral communication hardware.
- **Physical Operations Security:** Brick-and-mortar retail assets, warehouse inventory control spaces, and physical perimeter surveillance hardware.

- **Core Systems and E-Commerce Infrastructure:** Digital storefront platforms, internal inventory management frameworks, financial accounting packages, and local relational databases.
- **Enterprise Data Systems:** On-premises storage area networks (SAN), local data retention repositories, and active legacy/end-of-life systems requiring specialized compensating controls.
- **Network and Connectivity Architecture:** Internal corporate local area networks (LAN), perimeter routing, internet gateways, and remote access configurations.

3.0 Risk Assessment & Baseline Security Posture

3.1 Risk Description

The baseline assessment reveals a critical systemic vulnerability: Botium Toys currently lacks an institutionalized asset management program and operates without essential technical safeguards. This structural deficiency exposes the organization to catastrophic operational downtime, ransomware vulnerability, and severe legal penalties from international regulators.

3.2 Quantitative Risk Metrics

Risk Matrix	Score/Rate	Operational Justification
Composite Risk Score	Highly Critical	This severe score is driven directly by a systemic lack of technical controls and poor adherence to compliance best practices.
Asset Lost Impact	Medium	Rated as Medium solely because the IT department currently lacks the tracking mechanisms to know exactly which assets would be at risk during an active breach
Regulatory Fine Exposure	High	Rated as High because Botium Toys does not have the necessary controls to keep critical customer and transaction data private/secure.

4.0 NIST CSF Controls Assessment Checklist

This section evaluates the presence of administrative, technical, and physical safeguards across the infrastructure to establish defense-in-depth.

4.1 Administrative Controls Assessment

Control Name	Status (Yes/No)	Findings and Vulnerability Analysis
Principle of Least Privilege (PoLP)	No	Every employee in the company currently has access to sensitive internal databases. This includes customer credit card data and Personally Identifiable Information (PII/SPII), which creates a massive insider threat risk
Separation of Duties (SoD)	No	Critical operational tasks are not separated between different roles. This increases the chance of unauthorized or unverified data changes.
Disaster Recovery Plans	No	No formalized data restoration or business continuity documentation exists, introducing high operational downtime risk.
Enterprise Password Policies	Yes	A basic password policy exists, but the actual requirements are weak and do not meet modern password policy standards
Access Control Policies	Yes	Privacy policies and data maintenance processes have been formally drafted and enforced among personnel.
Identity Lifecycle Management	No	There is no strict lifecycle management for user accounts, meaning permissions are rarely reviewed or revoked when roles change.

Technical Controls Assessment

Control Name	Status (Yes/No)	Findings
Firewall	Yes	An active firewall is properly configured with structured rules to filter incoming perimeter traffic.
Antivirus (AV) Software	Yes	Installed across endpoint systems and routinely monitored by internal IT staff.

Intrusion Detection (IDS/IPS)	No	No network detection platform is deployed, which creates a critical visibility gap for active network intrusions.
Encryption	No	Customer financial assets are processed and stored locally in plaintext within the internal database without cryptographic protections.
Backups	No	Critical operating and user data are not backed up, leaving the system completely vulnerable to ransomware.
Password Management	No	There is no centralized password manager which leads to password fatigue, weak habits, and administrative strain on IT tickets.

Physical / Operational Controls Assessment

Control Name	Status (Yes/No)	Findings
Physical Locks	Yes	Front offices, storefront assets, and production warehouses are sufficiently restricted with physical locks.
CCTV Surveillance	Yes	Fully functional and up-to-date CCTV cameras overseeing operational perimeters.
Environmental Safety	Yes	Fully functional fire detection, alarm, and suppression hardware are installed on-site.

5.Regulatory Compliance Gaps

PCI-DSS Assessment (Financial Protections)

Compliance Name	Status (Non-Compliant/Compliant)	Description
Authorized Access Only	Non-Compliant	Credit card details are stored in plaintext and can be viewed by staff members or threat actors who have no business reason to see them
Secure Storage Environment	Non-Compliant	The internal database used for processing transactions is not properly isolated

Data Encryption Execution	Non-Compliant	Severe regulatory violation due to zero encryption on financial data at rest, in use or in transit.
---------------------------	---------------	---

EU GDPR Assessment (European Privacy Standards)

Compliance Name	Status (Non-Compliant/Compliant)	Description
PII & SPII Confidentiality	Non-Compliant	Storing European customer records (like names, emails, and addresses) in unencrypted databases fails basic privacy compliance rules.
72-Hour Breach Notification	Compliant	A formal incident notification plan exists to alert regulatory agencies and E.U. customers within 72 hours of exposure
Asset Classification & Asset Inventory	Non-Compliant	The IT department cannot currently identify which specific storage drives hold protected European user records.

6. Recommendations for Botium Toys IT Manager:

To bring Botium Toys into immediate alignment with international compliance frameworks and reduce structural risk, the following steps are recommended:

- **Technical Controls (Encryption & IDS):** Implement AES encryption for all credit card data and PII/SPII at rest, in use or in transit to satisfy PCI DSS and GDPR compliance requirements and Install a Network Intrusion Detection System (IDS) to monitor network traffic for anomalous behavior.
- **Administrative Controls (Access & Identity):** Enforce the Principle of Least Privilege and Separation of Duties so that employees only have access to data necessary for their specific roles and deploy a centralized Password Management System to enforce strong password complexity configurations to meet international password policy standards.

- **Business Continuity (Backups):** Establish a structured data backup schedule alongside a formal Disaster Recovery Plan to protect corporate infrastructure from potential data loss or operational downtime.